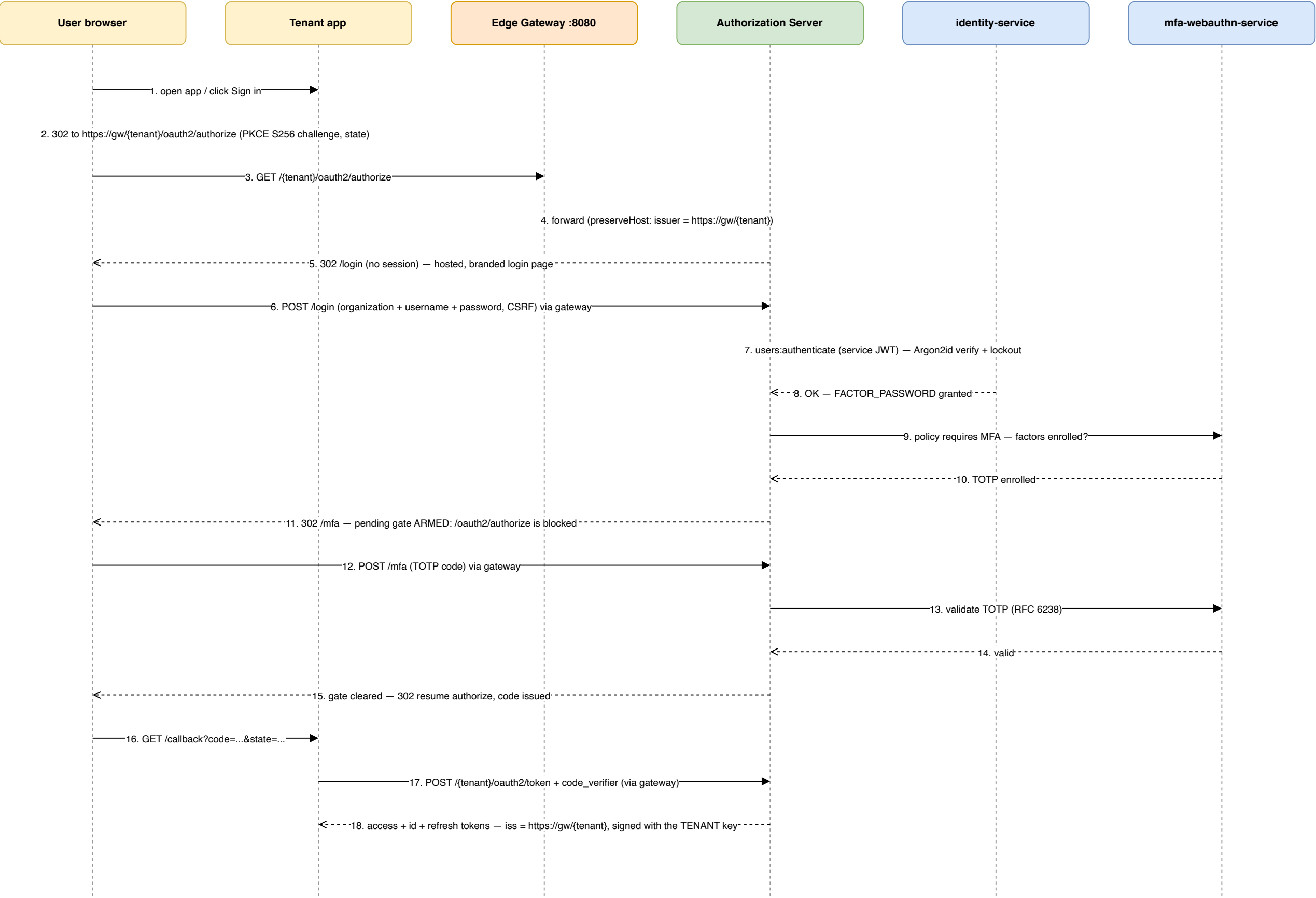


Hosted login with MFA step-up — authorization_code + PKCE through the per-tenant gateway issuer



Zero-trust: no code or token can be issued while the second factor is pending — MfaPendingGateFilter blocks /oauth2/authorize at the protocol chain, so a password-only session cannot mint tokens by navigating directly. Tokens carry the per-tenant issuer and are signed with the tenant's own key; resource servers verify signature + issuer allowlist + scope on every call.